WORKING MODEL OVERVIEW • V1.3.0 (MIT)

Agents in NYC • Oct 28, 2026

BreachBench: Adversarial Security Evals & Runtime Guardrail Shield for AI Agents

Open-Source Evaluation Suite & 3-Layer Defense-in-Depth for Tool-Using Models

Tanushree Umathe | MS Cybersecurity, NYU Tandon (Dec 2026)

github.com/tu2090-ops/breachbench

WHY IT MATTERS

AI coding and tool-using agents read untrusted repositories, emails, and logs while holding access to shells, APIs, and secrets. **Unshielded local models fail when attackers hide prompt injections or malicious scripts inside everyday files**—leaking credentials, obeying hidden overrides, or executing unsafe commands unless protected by deterministic runtime guardrails.

HOW THE WORKING MODEL WORKS — 4-STEP DEFENSE-IN-DEPTH FLOW

STEP 1 • PRE-INFERENCE

Input Pre-Screen

The Bouncer

Scans incoming files, packages, and prompts for hidden injections, malware hooks, and code flaws before the AI reads them.

STEP 2 • CONTEXT ISOLATION

Prompt Spotlighting

Quarantine

Wraps untrusted content in strict data boundaries so the AI treats external text as data to analyze, never instructions to obey.

STEP 3 • POST-GENERATION

Output Enforcement

Final Inspector

Checks the AI's response before it leaves—blocking secret/canary leaks, refusing malware generation, and neutralizing hijacked verdicts.

STEP 4 • EXECUTION CONTROL

Permission Gate

Human-in-the-Loop

Blocks any multi-machine or remote SSH action unless a human explicitly authorizes both the run and the target host.

WHAT BREACHBENCH EVALUATES — 6 CORE SECURITY DOMAINS

- **Prompt Injection & Tool Hijacking:** Tests resistance to indirect overrides, jailbreaks & secret exfiltration.
- **Code Vulnerability Detection:** Audits agent-reviewed code across 8 high-risk OWASP / CWE flaw classes.
- **Malware & Supply-Chain Hooks:** Catches reverse shells, obfuscated droppers, Unicode RLO & install hooks.
- **Phishing & MFA Social Engineering:** Evaluates triage of BEC, lookalike domains & MFA-fatigue lures.
- **OWASP API Security Surface:** Detects broken object-level authorization (BOLA/IDOR) & SSRF exposure.
- **Multi-Machine Authorization:** Verifies allowlist enforcement & immutable audit logs on remote runs.

HEADLINE BENCHMARK RESULT — BEFORE VS. AFTER RUNTIME SHIELD

LIVE EMPIRICAL EVALUATION

Local Coding Agent (qwen2.5-coder:1.5b via Ollama)

0 secret/canary leaks • **<3 ms** deterministic shield overhead • **100%** injection neutralization

26.7% Unshielded (4/15) → **100%** With Shield (15/15)

Try BreachBench or View This 1-Page Overview on Your Phone

Open-source CLI, FastAPI service, and reproducible benchmark datasets for OpenAI, Ollama, and custom agents.

```
pip install breachbench  |
https://github.com/tu2090-
```

1-Page PDF
Scan to open this overview sheet

GitHub Repo
Scan for code, benchmarks & docs